

Progress SP

Aktuální stav projektu AURA

David Strnadel, AK8BO - Bezpečnost operačních systémů

Aktualizace: 12. 5. 2026 | obhajoba: pátek 15. 5. 2026

Hlavní výstup	Strukturované bezpečnostní a QA reporty nad daty dostupnými běžné Android aplikaci
Stav repozitáře	Aktuální implementace je přiložená v GitHub repozitáři projektu

Co je cílem projektu

Na začátku projektu jsem uvažoval hlavně o mobilním bezpečnostním agentovi pro Android. Během vývoje se ale ukázalo, že nejzajímavější a zároveň realističtější směr není vytvořit další aplikaci pro běžného uživatele ani konkurovat antivirovým řešením nebo Google Play Protect.

Aktuální cíl projektu je jiný: AURA má být výzkumný a B2B reporting nástroj. Android aplikace v tomto pojetí není finální produkt sama o sobě. Slouží hlavně jako sběrná sonda, která z no-root prostředí získá maximum relevantních dat, uloží je do strukturovaného exportu a nad nimi se následně generují reporty.

Produktem projektu jsou tedy reporty, ne uživatelské UI aplikace. Cílovým uživatelem nejsou běžní uživatelé telefonu, ale spíše firmy a týmy zabývající se Android vývojem, QA, bezpečnostní revizí aplikací nebo interním hodnocením rizik. Smyslem je dodat jim jiný pohled na aplikaci: ne jako pentest, ne jako malware analýzu, ale jako vysvětlitelný report založený na datech, ke kterým se dá dostat bez root oprávnění.

Praktická otázka projektu tedy zní:

Kam až se dá v Androidu dostat bez root oprávnění a co užitečného lze z takto získaných dat říci o aplikacích, jejich oprávněních, komponentách, původu, rizikových kombinacích a obranné ploše?

Aktuální stav implementace

Projekt je nyní ve fázi funkčního research MVP. V repozitáři je implementovaná Android aplikace, která sbírá dostupná data o aplikacích v zařízení a vytváří strukturovaný JSON export. Nad exportem pak existují podpůrné nástroje pro evaluaci, redakci citlivých údajů a generování reportů.

Android část umí sbírat zejména:

- základní metadata aplikací dostupných přes PackageManager,
- deklarovaná a udělená oprávnění,
- aktivity, služby, receivers a providery,
- exportované komponenty a informaci, zda jsou chráněné oprávněním,
- instalační zdroj, podpisové digesty a systémový původ aplikace,
- vybrané special-access signály, například Accessibility Service, Notification Listener, overlay a request-install-packages,
- omezenou UsageStats korelaci v research scénáři, pokud je explicitně povolena.

Nad těmito daty běží rozhodovací a vysvětlovací vrstva. Ta se nesnaží aplikace hodnotit jen podle

počtu oprávnění. Rozlišuje například capability exposure, legitimitu role aplikace, provenienci, konkrétní evidence, akceschopnost uživatele a nejistotu.

Výsledek se ukládá jako JSON export a je možné z něj generovat reporty. Právě reporty jsou pro aktuální směr projektu hlavní výstup.

Dosavadní výstupy

V projektu už mám připravené tyto části:

- Android research aplikaci AURA v Kotlinu.
- Datový model pro snapshoty aplikací, evidence items, risk vector, decision trace, user risk story a evidence graph.
- Rozhodovací logiku pro role inference, provenance classification, risk decision engine, temporal episodes a defensive-surface findings.
- JSON export výsledků do privátního úložiště aplikace.
- Sadu neškodných testovacích aplikací pro řízené scénáře.
- Python evaluator pro porovnání AURA výstupů proti jednodušším baseline modelům.
- Report generator pro Markdown/HTML reporty.
- Export redactor pro přípravu reportů v různých úrovních citlivosti.
- Dokumentaci k observability limitům, risk modelu, privacy/ethics a testovacím scénářům.

Lokálně jsem ověřil dostupné testy, které nevyžadují běžící Android emulator. Gradle testovací běh pro `researchFullStandardDebug` unit testy skončil úspěšně. Dále jsem spustil Python unit testy pro podpůrné nástroje, kde proběhlo 27 testů a všechny skončily úspěšně.

Reporty jako hlavní produkt

Nejdůležitější posun oproti původní představě je v tom, jak chápu výstup projektu. UI Android aplikace je zatím velmi jednoduché a neplánuji ho do obhajoby výrazně zlepšovat. Není to priorita, protože pro aktuální použití nemá být hlavní hodnotou klikací aplikace.

Hlavní hodnotou jsou reporty, které mohou být užitečné například pro:

- QA tým, který chce další pohled na Android aplikaci před vydáním,
- vývojářský tým, který chce rychle vidět podezřelé kombinace oprávnění a komponent,
- bezpečnostní review, které potřebuje oddělit konkrétní zjištění od pouhé nejistoty,
- interní audit aplikací, kde je důležité pracovat s omezeními no-root prostředí.

Report nemá říkat „aplikace je malware“. Má spíš říct: toto bylo pozorováno, toto pozorováno nebylo, tyto části dávají smysl vzhledem k roli aplikace, tyto části si zaslouží revizi a tady jsou limity toho, co no-root agent vůbec může zjistit.

Co zbývá do obhajoby

Do obhajoby už nechci projekt rozšiřovat o nové velké funkce. Priorita je uzavřít existující MVP, spustit finální scénáře, vybrat ukázkové výstupy a připravit prezentaci tak, aby byl projekt pochopitelný i bez detailní znalosti celého repozitáře.

Datum	Plán dokončení
Úterý 12. 5. 2026	Odevzdat progress SP, sjednotit popis projektu a uzavřít rozsah pro obhajobu.
Středa 13. 5. 2026	Spustit finální emulátorové scénáře, stáhnout JSON exporty a uložit výsledky evaluátoru.
Čtvrtek 14. 5. 2026	Zpracovat výsledky do stručné tabulky, vybrat ukázkové reporty a dokončit prezentaci.
Pátek 15. 5. 2026	Projít demo, připravit repozitář a obhájit projekt.

Další směr po odevzdání

Ve vývoji chci pokračovat i po obhajobě. No-root část беру jako první výzkumnou linii: ukazuje, co lze zjistit z pozice běžné aplikace. Vedle toho bych chtěl časem přidat samostatný root lab nebo laboratorní režim, který by umožnil sbírat hlubší systémová data v kontrolovaném prostředí.

Tím by šlo porovnat dvě úrovně pohledu:

- co je možné říci z čistě no-root dat,
- a co se změní, když má výzkumný lab hlubší přístup k systému.

Tento směr by mohl být užitečný pro další výzkum i pro B2B reporting. Firmám by bylo možné ukázat nejen samotný nále, ale také rozdíl mezi běžně dostupnou observabilitou a hlubší laboratorní analýzou.

Zhodnocení

Aktuální stav projektu odpovídá závěrečné fázi původního plánu. Rešeršní a návrhová část se postupně přetavila do funkčního MVP, které sbírá dostupná Android data, vytváří exporty a umožňuje z nich generovat reporty.

Za hlavní přínos projektu považuji právě tento posun: nesnažím se dodat další mobilní bezpečnostní aplikaci pro koncového uživatele, ale ověřuji, jak daleko se dá dostat s no-root sběrem dat a jak z těchto dat vytvořit srozumitelný, opatrný a prakticky použitelný report pro Android vývoj a QA.